

API Security Risk Analysis Report

Prepared by: Mlungisi Sibitane

Date: June 2026

Future Interns Cyber Security Internship Task 3

Executive Summary

This API Security Risk Analysis was conducted on the publicly available JSONPlaceholder API to evaluate common API security considerations and identify potential risks that could affect real-world applications if similar configurations were deployed in production environments.

The assessment included reviewing API documentation, testing endpoints using Postman, inspecting response headers, and analyzing returned data. Several observations were identified, including unrestricted access to API resources, exposure of user-related information, lack of visible authentication controls, and the absence of rate-limiting indicators within API responses.

While JSONPlaceholder is intentionally designed as a public testing API and does not represent a production environment, the findings demonstrate common API security risks that organizations should address when developing and deploying APIs. Recommendations have been provided to improve authentication, data protection, access control, and API abuse prevention mechanisms.

Scope and Methodology

Scope

This assessment focused on the public JSONPlaceholder API.

Target API:

<https://jsonplaceholder.typicode.com>

Included Activities

- API documentation review
- Endpoint testing
- Header inspection
- Response analysis
- Risk identification
- Security recommendations

Excluded Activities

- Authentication bypass attempts
- Exploitation testing
- Denial-of-Service testing
- Data manipulation
- Unauthorized access attempts

Methodology

Step 1: Documentation Review

Reviewed available API documentation and endpoint structure.

Step 2: Endpoint Testing

Used Postman to send GET requests to public endpoints.

Step 3: Header Analysis

Reviewed HTTP response headers for security-related controls.

Step 4: Response Analysis

Examined returned data for excessive information exposure.

Step 5: Risk Assessment

Classified findings based on potential business impact and security implications.

Findings

Finding F-01:

- Open Public Endpoints

Risk Level:

- Medium

Response returned user information without authentication.

Request:

- GET <https://jsonplaceholder.typicode.com/users>

Description:

- The API allows users to retrieve data without requiring authentication or authorization.

Business Impact:

- If deployed in production, unauthorized users could access sensitive business or customer information.

Recommendation:

- Implement authentication mechanisms such as:

- OAuth 2.0
- JWT Tokens
- API Keys

Finding F-02:

- Excessive Data Exposure

Risk Level:

- Medium

Evidence

- The /users endpoint returns:

- Name
- Email
- Phone Number
- Website
- Address Information
- Company Information

Description:

- The API exposes more information than may be necessary for certain business functions.

Business Impact:

- Excessive exposure increases privacy and data leakage risks.

Recommendation:

- Apply data minimization principles and return only required fields.

Finding F-03

- Missing Authentication Controls

Risk Level:

- Medium

Tools Used:

- Postman + Documentaion Review

Evidence:

- No authentication token was required when accessing user data.

Description:

- Sensitive resources can be accessed without identity verification.

Business Impact:

- Production APIs lacking authentication may expose customer information and business assets.

Recommendation:

Implement authentication and role-based access control (RBAC).

Finding F-04

- Missing Rate Limiting Indicators

Risk Level:

- Low

Evidence:

- Response headers did not contain:

- X-RateLimit-Limit
- X-RateLimit-Remaining
- X-RateLimit-Reset

Description:

No visible rate-limiting controls were observed during testing.

Business Impact:

- Could increase risk of automated abuse if similar configurations existed in production systems.

Recommendation:

- Implement API rate limiting and monitoring controls.

Conclusion

The API Security Risk Analysis of the JSONPlaceholder API identified several common security considerations, including open public endpoints, excessive data exposure, lack of authentication controls, and the absence of visible rate-limiting mechanisms. While the API is intentionally designed for testing and learning purposes, these observations highlight risks that could have significant security implications if present in a production environment.

The assessment demonstrated the importance of implementing strong authentication, access control, data minimization, and abuse prevention measures when developing modern APIs. By addressing these areas, organizations can better protect sensitive information, reduce unauthorized access risks, and improve the overall security posture of their applications.

Overall, the API exhibited characteristics that would represent a Medium Risk level in a real-world environment, emphasizing the need for secure API design and regular security assessments.